LABORATUVAR 2 · CMAK KÖPRÜLÜ VINÇ · Tek Kirişli Köprülü Vinç (SAMİB)

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad YUSUF DURSUN · 230541104 **Grup** GÜNDÜZ B **Tarih**

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi (köprülü vinç): Hareket PLC'si · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · 3 inverter (kaldırma, araba, köprü) · yük hücresi ölçüm modülü · telsiz kumanda alıcısı · **internete açık uzak bakım modülü (4G)** · bulut telemetri (yük, çalışma saati) · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı
Zafiyet seti, föydeki örnek makineyle aynı alınmıştır (eğitim senaryosu).

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Bölge (Zone)	Varlıklar	Hedef SL
Z0 – Dış / İnternet	Bulut telemetri servisi, üretici (Çakmak Vinç) servis ağı	—
Z1 – Uzak Erişim DMZ	Uzak bakım modülü (taşınacak), jump server, VPN geçidi	SL 2–3
Z2 – Kontrol Bölgesi	Hareket PLC'si, HMI, 3 inverter, telsiz alıcının hareket komut çıkışı	SL 2
Z3 – Emniyet Bölgesi (en kritik)	Safety PLC, yük hücresi ölçüm modülü, limit şalterleri, acil stoplar, telsiz acil stop çıkışı, STO ve fren devresi	SL 3
Z4 – Kablosuz	Wi-Fi AP — kontrol bölgesinden ayrı, izole	SL 1

Bölgeye konmayanlar: **2 kilitsiz USB** fiziksel erişim noktasıdır (kilitlenir); **admin/admin** bir varlık değil zafiyettir (silinir, kişisel hesaplarla değiştirilir).

2 Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Bugün PLC ile aynı ağda, yani fiilen **Z2 Kontrol Bölgesi**'nde ve 4G ile doğrudan internete açık. **Orada kalamaz.** İnternete açık cihaz en güvenilmez bölgenin kenarına aittir; kontrol bölgesinde durursa internetten inverterlere, yük ölçüm modülüne ve Safety PLC'ye tek adımda geçilir. **Z1 DMZ**'ye taşınmalı, kontrol bölgesine yalnız denetlenen bir conduit üzerinden ve varsayılan kapalı olarak erişmelidir.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

- **C1 İnternet ↔ DMZ:** güvenlik duvarı; yalnız VPN, MFA, izinli kaynak, varsayılan kapalı, oturum kaydı.
- **C2 DMZ ↔ Kontrol:** yalnız jump server'dan, yalnız gerekli protokol/port, kişisel hesap, süre sınırlı, loglama; **uzaktan vinç hareketi komutu yasak.**
- **C3 Kontrol ↔ Emniyet (en sıkı):** yalnız durum okuma; aşırı yük eşiği, kalibrasyon ve Safety PLC programı uzaktan değiştirilemez — yalnız yerinde, test ağırlığıyla doğrulanarak.
- **C4 Kontrol → Bulut:** yalnız giden, TLS şifreli veri; buluttan komut kabul edilmez.
- **C5 Telsiz verici ↔ alıcı:** eşleşmiş kimlik, kodlu/şifreli iletim, sinyal kaybında durma, acil stop öncelikli.
- **C6 Wi-Fi ↔ Kontrol:** varsayılan kapalı; gerekirse yalnız okuma, WPA3. **Fiziksel:** USB kilitli, HMI port 80 → HTTPS + kimlik doğrulama.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — doğrudan erişimde vinç ağı internete açık kalır; jump server tek, izlenen ve sertleştirilmiş giriş noktasıdır.
Tünel?	Açık / VPN	**VPN** — trafik şifrelenir, yalnız yetkili uç bağlanır; 4G modemin açık portu internetten taranıp bulunur.
Kimlik?	Parola / MFA	**MFA** — admin/admin gibi parolalar tahmin edilir/çalınır; ikinci faktör tek başına parolayı yetersiz kılar.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — kalibrasyon veya limit değişikliğini kimin yaptığı izlenir; ayrılan personelin hesabı tek tek kapatılır.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — parametre değişikliklerinin kanıtı; kaza/olay incelemesi ve CRA bildirimi için gerekli.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — yalnız onaylı bakım penceresinde, vinç yüksüz ve sahada yetkili kişi varken açılır, süre bitince kendiliğinden kapanır.

📄 Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.